

LLM-ERP Secrets 輪換 SOP (繁體中文)

密鑰外洩 = 系統淪陷。定期輪換是底線。對象：客戶 IT、我們的維運、資安顧問。

目錄

- 1. [Secrets 清單與輪換週期](#)
- 2. [JWT_SECRET 輪換 \(90 天 \)](#)
- 3. [PostgreSQL 密碼輪換 \(半年 \)](#)
- 4. [LLM_API_KEY 輪換 \(年度 / 緊急 \)](#)
- 5. [TLS 憑證輪換 \(90 天 \)](#)
- 6. [WireGuard 公鑰輪換 \(年度 \)](#)
- 7. [緊急應變：Secret 外洩怎辦](#)
- 8. [自動化 + 監控](#)

1. Secrets 清單與輪換週期

Secret	影響範圍	輪換週期	外洩風險	處理 SOP
JWT_SECRET	所有 user token 全失效	90 天	● 高	\$2
POSTGRES_PASSWORD	DB 連線	半年	● 中	\$3
LLM_API_KEY	API 帳單可能爆炸	年度 / 緊急	● 高	\$4
TLS cert	HTTPS	90 天 (auto)	● 低	\$5
WireGuard pubkey	MESH VPN	年度	● 中	\$6
LINE Channel secret	LINE Bot 接收	變更時	● 中	LINE Console
SMTP credential	寄信	半年	● 低	改 .env

2. JWT_SECRET 輪換 (90 天)

2.1 為什麼要輪換

JWT 是 signed by `JWT_SECRET` 。一旦外洩，攻擊者可偽造任意身分。

2.2 一般輪換 (無人外洩跡象)

```
# 1. 產生新 secret
NEW_SECRET=$(openssl rand -hex 32)
echo "新 JWT_SECRET: $NEW_SECRET"

# 2. 備份舊 .env
cp backend/.env backend/.env.backup-$(date +%F)

# 3. 替換
sed -i "s|^JWT_SECRET=.*|JWT_SECRET=$NEW_SECRET|" backend/.env

# 4. 重啟 backend
docker compose restart backend

# 5. 通知所有使用者重新登入
# (舊 JWT 全部失效)
```

2.3 零停機輪換 (進階：雙 key 並存)

實作 JWT `kid` (key id) header 支援多 key：

```
# 在 JWT payload 加 kid="v2"
# 同時保留 v1 key 解舊 token、v2 簽新 token
# 等所有 v1 過期 (24 小時後) 才下架 v1
```

完整實作：規劃 Phase 2，目前先用 §2.2 簡單輪換。

2.4 提醒所有人

JWT_SECRET 換完，所有人舊 token 立刻失效：

- 桌機 UI：自動跳登入頁
- Mobile App：自動 logout (401 handler)
- LINE Bot：使用者重新綁定

事前廣播：

[LINE 群組通知]

明天 02:00 我們會做安全維護 (JWT 輪換)，所有人重新登入即可。
預估停機時間：30 秒。

3. PostgreSQL 密碼輪換 (半年)

3.1 流程

```
# 1. 產新密碼
NEW_PG=$(openssl rand -base64 32)

# 2. 連 DB 改密碼
docker compose exec db psql -U erp -d erp \
    -c "ALTER USER erp WITH PASSWORD '$NEW_PG';"

# 3. 改 .env
sed -i "s|^POSTGRES_PASSWORD=.*|POSTGRES_PASSWORD=$NEW_PG|" backend/.env

# 4. 同步 DATABASE_URL
sed -i "s|postgres://erp:[^@]*@postgres://erp:$NEW_PG@|" backend/.env

# 5. 重啟 backend (DB 不用重啟)
docker compose restart backend
```

3.2 驗證

```
docker compose exec backend python -c "
import asyncio
from app.database import engine
async def t():
    async with engine.connect() as c:
        r = await c.exec_driver_sql('SELECT 1')
        print('DB OK:', r.scalar())
asyncio.run(t())
"
```

4. LLM_API_KEY 輪換

4.1 觸發條件

1. 年度週期：每年 1/1

2. 緊急：發現異常用量 / 帳單暴增 / 在 GitHub commit 中誤上傳

4.2 緊急輪換流程 (15 分鐘)

```
# 1. 立刻去 provider console 「失效舊 key」
#   - Anthropic : console.anthropic.com → API Keys → Delete
#   - OpenAI : platform.openai.com → API Keys → Revoke
#   - DeepSeek : platform.deepseek.com → API Keys

# 2. 產新 key

# 3. 改 .env
sed -i "s|^LLM_API_KEY=.*|LLM_API_KEY=sk-new...|" backend/.env

# 4. 重啟
docker compose restart backend

# 5. 驗證
curl -s http://localhost:8000/api/health | jq .llm_provider
# 應該還是有效 (key 換了但 provider 不變)

# 6. 跑 1 個對話確認
curl -X POST http://localhost:8000/api/chat-v2 \
  -H "Authorization: Bearer $TOKEN" \
  -H "Content-Type: application/json" \
  -d '{"message": "test", "session_id": "rotation-check"}'
```

4.3 事後檢查

```
# 看舊 key 是否還在用 (log 應該不再出現舊 key fingerprint)
docker compose logs backend --since 5m | grep -i "401\|auth.*fail"
```

5. TLS 憑證輪換 (90 天)

5.1 Let's Encrypt 全自動

```
# 安裝 certbot (若還沒)
apt install certbot

# 第一次申請
certbot certonly --webroot -w /var/www/certbot \
  -d your-domain.example -d www.your-domain.example \
  --email admin@your-domain.example --agree-tos

# 設 cron 自動 renew
echo '0 3 * * * certbot renew --quiet --post-hook "nginx -s reload"' \
  | sudo crontab -

# 手動測試 renew
certbot renew --dry-run
```

5.2 手動輪換 (自簽 cert)

```
# 產新 cert (給內網用)
openssl req -x509 -nodes -days 365 -newkey rsa:2048 \
  -keyout /etc/nginx/certs/erp.key \
  -out /etc/nginx/certs/erp.crt \
  -subj "/CN=erp.local"

# Reload nginx
docker compose exec frontend nginx -s reload
```

6. WireGuard 公鑰輪換 (年度)

6.1 流程

每年同步輪換 HQ 和所有 Factory Node 的 keypair。

```
# 在每個節點 (HQ + 每個 factory)
wg genkey | tee privatekey | wg pubkey > publickey
# 紀錄 publickey 內容

# HQ 端：更新 wg0.conf - peers 改成所有 factory 的新 publickey
# Factory 端：更新 wg0.conf - peer 改成 HQ 的新 publickey

# 重啟 wireguard
wg-quick down wg0 && wg-quick up wg0
```

6.2 驗證

```
# 在 HQ
wg show
# 應該看到所有 peer 都 "latest handshake" 在 1 分鐘內
```

7. 緊急應變：Secret 外洩

7.1 偵測

訊號	行動
GitGuardian 警報	立刻 §7.2
LLM 帳單暴增	立刻 §7.2
公開頻道看到 secret	立刻 §7.2
不明 IP 大量 401/403	§7.3 加白名單
Audit log 異常 session	§7.4 撤銷

7.2 黃金 15 分鐘

外洩後 15 分鐘內必做：

```
T+0min: 確認外洩範圍 (哪個 secret? 哪個 commit?)
T+2min: provider console 失效舊 key
T+5min: 產新 secret 並寫進 .env
T+8min: docker compose restart backend
T+12min: 跑 smoke test 確認新 secret 生效
T+15min: 通報內部 + (視情況) 通報客戶
```

7.3 加 IP 白名單

```
# nginx/conf.d/default.conf
location /api/ {
    # 緊急時只允許客戶辦公室 IP
    allow 203.0.113.0/24; # 客戶辦公室
    deny all;
    proxy_pass http://backend:8000;
}
```

7.4 撤銷可疑 session

```
# 改 JWT_SECRET → 所有 session 失效
NEW=$(openssl rand -hex 32)
sed -i "s|^JWT_SECRET=.*|JWT_SECRET=$NEW|" backend/.env
docker compose restart backend
```

7.5 事後 RCA

寫入 `docs/incidents/YYYY-MM-DD-secret-leak.md` :

- 時間軸
- 外洩 secret 種類
- 影響範圍
- 修補動作
- 預防措施

8. 自動化 + 監控

8.1 排程提醒

加入 cron :

```
# 每月 1 號檢查到期日
0 9 1 * * /opt/llm-erp/scripts/secret_age_check.sh
```

`secret_age_check.sh` :

```
#!/bin/bash
# 算 .env 中 JWT_SECRET 上次改的時間
LAST_CHANGE=$(stat -c %Y backend/.env)
NOW=$(date +%s)
AGE_DAYS=$(( (NOW - LAST_CHANGE) / 86400 ))

if [ $AGE_DAYS -gt 80 ]; then
    curl -X POST https://notify-api.line.me/api/notify \
        -H "Authorization: Bearer $LINE_TOKEN" \
        -d "message=⚠️ JWT_SECRET 已 $AGE_DAYS 天未輪換，請 $2"
fi
```

8.2 GitGuardian 整合

在 git pre-commit hook 加：

```
# .git/hooks/pre-commit
ggshield secret scan pre-commit
```

確保 secret 永遠不會被 commit。



相關文件

- [架構藍圖](#) (§5 Secrets Management 概覽)
- [備份還原 SOP](#) (含 .env 備份)
- [支援運維手冊](#)
- 對應英文版：`SECRETS_ROTATION_SOP_EN.md`

版本：2.6 · 最後更新：2026-05-14